

Joint SOC 2 + PCI DSS RFP Negotiation Playbook for NBFCs

How to run a fair, defensible, NBFC-calibrated procurement for joint SOC 2 + PCI DSS audit firms. Covers scoring weights, fee benchmarking, scope-creep controls, NCNR clauses, partner-rotation insurance, vendor non-disclosure, and the five-step negotiation order that produces let-me-talk-to-my-partner concessions.

1. Decide single-firm vs dual-firm engagement model

A single firm offering SOC 2 + ISO 27001 + NIST CSF 2.0 (the "Integrated Audit Firm" model) and a separate PCI QSA firm is the NBFC norm. Reasons:

Model	Pros	Cons
Single firm (Big-4) for SOC 2 + ISO + NIST; separate QSA for PCI	Lower coordination cost; unified UCM; 15-25% bundle reward	QSA independence barrier; one firm on data breach triage
Single firm for all (firm is both AICPA & QSA)	Cheapest; one contract	Independence issues if firm sold subservice OR PCI misses the firm's other pra
Two separate CPAs + one separate QSA (three contracts)	Maximum independence; best optics for RBI IS Audit	Hardest to coordinate; subservice overlaps

NBFC CISO trap: bidding single-firm SOC2+PCI saves 5-7% but RBI IS Audit + DPDP + Cert-IN investigations need a single accountable party. The audit firm who wrote your SOC 2 must defend it in CERT-IN litigation. Pick a firm you can face in court.

2. Fee benchmarks (NBFC size categories)

NBFC size	SOC 2 fee-INR	PCI QSA fee-INR	Margin to push
Small (<500 Cr AUM)	Rs 22-35 L	Rs 35-55 L	15-20% through scope lock
Medium (500-5,000 Cr)	Rs 35-65 L	Rs 60-1.0 Cr	12-18% via bridge + SSAE-18 reuse
Large (5,000-50,000 Cr)	Rs 65 L - 1.4 Cr	Rs 1.0 - 1.8 Cr	8-12% - fee is near floor
Very large (>50,000 Cr)	Rs 1.4-2.5 Cr	Rs 1.8-3.2 Cr	Hard to push - Big-4 only

Fee anchor: SOC 2 fee per Rs 1,000 Cr AUM should be ~10-12 k for medium NBFCs. Anything >18 k per 1,000 Cr AUM is service-density rich; push back via scope lock. Anything <6 k per 1,000 Cr AUM is partner-light; risk finding many control gaps.

3. Scope-creep controls - lock the master scope document

Three scope-creep vectors hit NBFC audits: (a) new production system slipped in by engineering, (b) DPDP addition pulls audit into custodial-data systems, (c) fintech partner adds a downstream data flow. Lock a 'scope moat' in the contract:

Master scope document (MSD) - load into the contract

(i) Named CDE systems list with CIDR / AMI / version; (ii) Named SOC 2 services list with subdomain; (iii) Named ISO control categories by Annex A clause; (iv) Named subservice organisations; (v) Named TIC / DESC exclusion (junk) zones. Any deviation beyond 5% of system volume triggers a contract addendum, not a fee top-up. Demand that the audit firm submit a 'scope-conflict register' within 5 days of any new system going live.

4. NCNR / kill-fee clause

Audit firms always want NCNR (Non-Cancellable / Non-Returnable). NBFC pushback:

Defensible NCNR formula

If NBFC terminates without cause within 30 days of fieldwork start, NBFC pays 10% of contract value (kill fee). If NBFC terminates within 60-180 days of fieldwork start, NBFC pays for % work done + 5% onboarding. Beyond 180 days, NBFC pays completion-cost-only. This protects against Big-4's 'no take-back' clause that costs you Rs 80 L for cancelling in week 4.

Big-4 trap: An NCNR clause with "NBFC pays full fee" if NBFC terminates for any reason including finding a partner-grade staff mismatch. Avoid.

5. Partner-rotation insurance

Audit firms rotate partners every 5-7 years (AICPA / ICAI). If your engagement partner rotates mid-engagement you face disruption. Negotiate:

- Engagement partner continuity for the 12-month scope period - written into contract.

- If rotation unavoidable, partner still on retainer for 2 bridge cycles at no extra cost.

- If rotation + lead-manager rotation together, NBFC option to terminate without kill-fee.

6. Subservice / carve-out vs inclusive method

For AWS / cloud providers, NBFC has two choices:

Carve-out (default for AWS)

NBFC excludes AWS from its SOC 2 boundary and references AWS's own SOC 2 (or ISO 27001, PCI DSS) via the AWS SOC 2 report. Cheaper, faster, but auditor may limit their reliance on the carve-out partner.

Inclusive

NBFC pulls AWS into the SOC 2 boundary and the auditor tests AWS directly. More expensive, more coverage, but rarely feasible across hundreds of AWS services and regions.

NBFC practice: Choose carved-out method 80% of the time. In a carve-out, demand auditor's reliance test - they must test transition controls (NBFC-to-AWS IAM, SSH keys, KMS) plus read the AWS SOC 2 last quarter.

7. Five-step negotiation order

Step 1 - Pin the scope

Lock MSD in writing before fee negotiation. Auditor pricing is driven by scope hours, and you cannot move the price without moving scope.

Step 2 - Negotiate on fee envelope, not rate-card

Auditors say 'our rate card is fixed'. Reframe: 'I have a fee envelope of Rs 70 L or Rs 1.1 Cr including QSA. Please tell me where you can fit.' This is the way to drive trade-offs: PCI sample size vs SOC 2 sample size, ASV scan front-loaded, etc.

Step 3 - Trade cycle-time for fee

Auditors always want to push fieldwork to later (giving them summer holiday). NBFC trade: 'If you start by 15 Aug, I will close your scope at full fee.' Cycle-time is the auditor's real cost; fee is secondary.

Step 4 - Trade acceptance-test for fee

Auditors always want to bring their own junior resource to test. NBFC offers to co-test (NBFC walks the test plan, auditor reviews). Saves Rs 12-25 L in staff days; auditor's quality risk goes up marginally.

Step 5 - Lock the deal on small print, never headline

Headline fee is rarely the deal-breaker. Small print - kill-fee, scope-conflict register, partner-rotation insurance, subservice carve-out reliance - is. Spend last 30 minutes on small print.

8. The ten clauses that protect NBFC in the contract

1. Master Scope Document (MSD) lock

Audit firm must accept NBFC's MSD at contract signing. Any deviation >5% volume requires written amendment.

2. Subservice carve-out clause

Carved-out subservice orgs named explicitly; auditor's reliance test required every ROC cycle.

3. Cycle-time commitment

Draft report within 14 days of fieldwork closure. Final within 7 days of management response.

4. Partner / manager continuity

Continuity clause ensuring engagement partner + manager fixed for 12-month scope period unless NBFC consents otherwise.

5. NCNR / kill-fee formula

Mutual kill-fee formula; no-fault termination right for repeated control deviation or material finding.

6. Indemnity + insurance

PI / E&O; cover >=Rs 50 Cr, NBFC named additional insured; no-claims certificate.

7. Confidentiality & data residency

Audit data (sample screenshots, VPN access) stays in India (or RBI-required region). No offshore senior review.

8. Multi-clock breach escalation

Audit firm must align with CERT-IN 6h / RBI 2h / DPDP 72h / acquirer 24h / contractual customer notification clauses.

9. Subservice duplication prevention

If the SOC 2 firm is the same as the QSA firm, only one hourly rate catalogue applies; no double-billing for shared testing.

10. Right-to-audit auditor

NBFC retains right to inspect auditor's internal working papers (sample sheets, scoping memos, draft findings) at auditor's office during engagement.

9. Common NBFC negotiation mistakes

Mistake 1 - Picking on fee alone

Cheap firm has cost-of-corners issues - junior staff, half samples, late draft. Better to pick quality firm at +10% and use them next year too.

Mistake 2 - Skipping NDA pre-RFP

Giving a candidate firm the full RFP without NDA leaks scope to subservice providers (and to their peers). Mutually sign RFP-stage NDA first.

Mistake 3 - Awarding before pre-engagement scoping

Audit firm needs to do 2-day pre-engagement scoping at half cost before the contract. This reveals scope reality.

Mistake 4 - No cycle-time plank

Firm slips fieldwork to November, draft to January; client is late for SOC 2 customer portal. Lock cycle in scope.

Mistake 5 - No subservice org list refresh

AWS keeps adding services; list must be refreshed at Q4 each year.

Mistake 6 - Wrong independence model

Choosing Big-4 firm that also does your transformation consulting gives AICPA / RBI independence issues.

Mistake 7 - Confusing ROC + advisory

PCI QSA offering ROC + general advisory hours = scope creep. Cap advisory at <=15% of ROC hours.

Mistake 8 - Forgetting CERT-IN 6h drill

Audit firm's IR role must include CERT-IN 6h drill simulation annually.

Mistake 9 - Letting auditor write the SoA

ISO SoA must be NBFC's. Auditor reviews; do not let them write it.

Mistake 10 - No MBA - 'manager buys audit'

Don't let manager-level sponsor pick firm alone. Bring CISO + DPO + CFO + audit committee chair into scoring.

10. Negotiation cheat-sheet (use in the meeting)

When the audit firm says:

"Our rate card is fixed."

Reply: "That's fine. I have an envelope. Tell me where you can fit. Don't bother showing me rate cards."

"We need to add this scope to the SOC 2 price."

Reply: "Please quote the change in fee and the change in audit days separately. And please flag the change to MSD as a contract amendment."

"You don't need the carve-out for AWS."

Reply: "Yes we do - RBI IS Audit will want to see our subservice carve-out reliance process documented. The carve-out costs you Rs 3 L; the alternative costs us Rs 40 L."

"NCNR is policy."

Reply: "So the contract is non-cancellable for either side. I'll take it on those terms if you'll accept our kill-fee formula and our partner-rotation clause."

"We've never offered a no-claims certificate."

Reply: "OK then I'll need the underwriter letter direct from your PI insurer. That's tighter than a no-claims certificate."

11. Quick scoring rubric (1-5, weighted)

Criterion	Weight	Score 1	Score 5
NBFC / payment-aggregator SOC 2 track record	25%	<3 SOC 2 reports in 36 months	>=10 + named NBFC refs
Methodology + plan-of-test quality	25%	Generic template	NBFC-specific TSCs + DPDP integration
Key-staff quality	20%	Manager unknown	Partner = ex-RBI / SEBI regulator
Fee (absolute)	20%	>benchmark +20%	<benchmark -10%
Insurance + indemnity + independence	10%	Standard	PI 50 Cr + indemnity + independence letter

12. Closing checklist - contract ready for signature

- MSD attached to contract as Schedule A.
- Subservice org list attached as Schedule B.
- Kill-fee / NCNR clause + partner rotation clauses in main body.
- Indemnity + insurance certificate attached.
- Confidentiality + data residency clause in main body.
- Multi-clock breach escalation process documented.
- Cycle-time commitments calendared.
- Engagement partner + manager named + resumes attached.
- Pricing schedule - firm-fixed + hourly over/under - attached.

Right-to-audit clause for NBFC included.